

Lab 1 – PatientPath Descriptive Paper

Stephen Garrison

Old Dominion University

CS411

Dr. Sumaya Sanober

9/27/2026

Version 1

Table of Contents

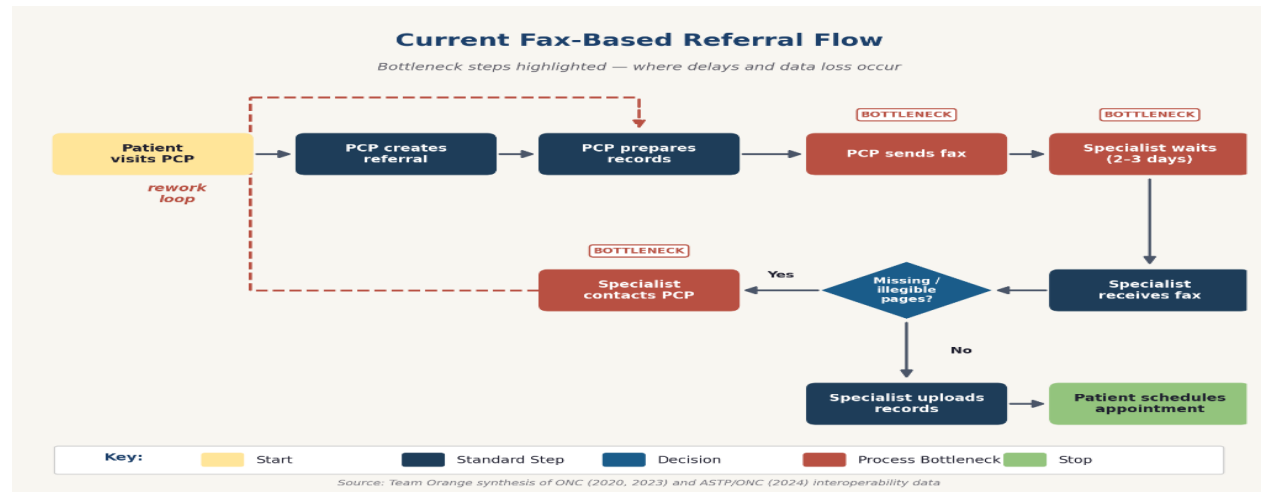
1	Introduction.....	3
2	Product Description.....	7
2.1	Key Product Features and Capabilities	8
2.2	Major Components (Hardware/Software).....	11
3	Identification of Case Study.....	13
4	Glossary	17
5	References.....	21

List of Figures

Figure 1: Fax Flow.....	4
Figure 2: Impact.....	5

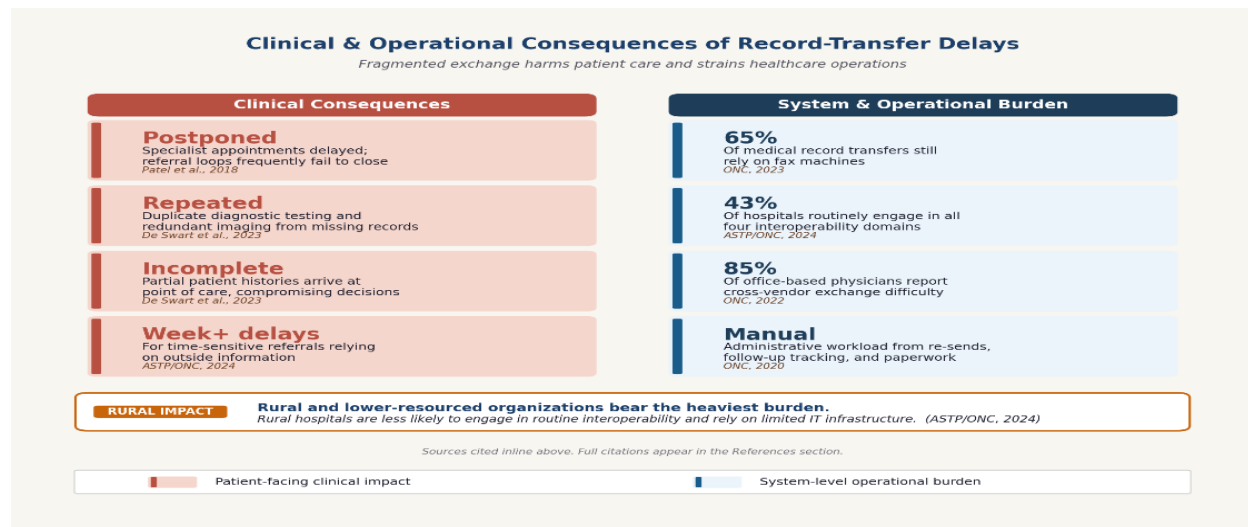
1 Introduction

In the United States, healthcare continues to rely on outdated mechanisms for exchanging patient information, and the result is measurable delay, administrative burden, and clinical risk. Despite the widespread availability of digital alternatives, roughly two-thirds of hospitals still routinely rely on mail or fax to exchange patient records (ONC, 2023), and only 43% of hospitals routinely engage in all four core interoperability domains: sending, receiving, finding, and integrating records (ASTP/ONC, 2024). The gap widens sharply at the edges of the network, where only 16% of hospitals regularly share records with long-term or post-acute providers outside their own network and just 17% do so with behavioral health providers (ASTP/ONC, 2024). The same pattern holds in ambulatory care, where 85% of office-based physicians report difficulty transferring records across different EHR vendors and 71% work with referral partners that lack any exchange capability at all (ONC, 2022). Taken together, these figures describe a fragmented national system in which critical patient information is too often locked behind incompatible software, proprietary formats, and paper-based workflows (see Figure 1).

Figure 1*Fax Flow*

These gaps translate into real harm for providers, their support staff, and their patients. Time-sensitive referrals stall while staff resend documents, issue repeat requests, and track paperwork status by hand (ONC, 2020). Handoffs between primary care and specialists arrive incomplete, and referral loops frequently fail to close (Patel et al., 2018). When information is missing at the point of care, clinicians order unnecessary repeat diagnostics, duplicate imaging, and redundant lab work, which drives up cost while further delaying treatment (De Swart et al., 2023). The burden falls hardest on rural and lower-resourced organizations, which are simultaneously the least likely to engage in routine interoperability (ASTP/ONC, 2024) and the most likely to operate on constrained IT infrastructure and erratic connectivity (see Figure 2). A functional solution must therefore do more than digitize the existing workflow. It must be secure, interoperable with the EHR systems already in place, usable in real-world network conditions, and aligned with HIPAA requirements at every layer.

Figure 2

Impact

A meaningful solution in this space must address six interlocking problem characteristics. The first is the inefficiency of the transfer process itself, which delays or corrupts records in transit. The second is the disconnection between systems, which limits interoperability across organizational boundaries. The third is patient privacy exposure created by outdated security protocols. The fourth is poor usability, which slows clinical adoption even where the underlying technology is sound. The fifth is rigid architecture that cannot scale as healthcare networks grow. The sixth is the connectivity constraint that disqualifies online-only tools from rural deployment.

A platform that addresses only a portion of these characteristics, such as one that achieves interoperability but fails in low-bandwidth environments, leaves the populations most in need and most likely to benefit still underserved.

PatientPath is the proposed solution: a secure, centralized, web-based record-sharing and referral-coordination platform designed to bridge organizations and the EHR systems they

already use rather than replace them. Built on an API-first architecture with FHIR R4 and HL7 compatibility, PatientPath combines real-time digital record exchange, automated referral tracking, role-based access control, end-to-end encryption, and offline synchronization for rural and low-bandwidth clinics. Its intended users are hospitals, private practices, specialists, rural providers, and patients, and it is engineered to be HIPAA-aligned by design. The remainder of this document details PatientPath's features and capabilities, its major hardware and software components, and the case study group against which the platform will be evaluated in a representative rural referral scenario. PatientPath is engineered to be HIPAA aligned by design. The remainder of this document details PatientPath's features and capabilities, its major hardware and software components, and the case study group against which the platform will be evaluated in a representative rural referral scenario.

2 Product Description

PatientPath is a secure, web-based platform that replaces the fax-driven exchange of medical records with real-time digital record sharing and automated referral coordination. Rather than competing with the EHR systems already in use, the platform sits between organizations as an interoperability layer: it ingests records from existing systems, normalizes them to FHIR R4, and routes them across organizational boundaries through a single API gateway. Providers, administrative staff, and patients each interact with PatientPath through a role-appropriate interface, while every transaction is encrypted, logged, and bound to explicit patient consent.

The goal of PatientPath is to eliminate the delays, document loss, and administrative burden that result from fax-based workflows, while strengthening the privacy and security posture that aging communication channels actively undermine. The platform's specific objectives are: (1) achieve cross-organization record exchange in real time using FHIR R4 and HL7 v2.x without requiring providers to replace their existing EHRs; (2) close the referral loop through a single-form workflow with automated status tracking, stale-referral alerts, and supervisor escalation; (3) enforce HIPAA-aligned security through end-to-end encryption, role-based access control, multi-factor authentication, and an immutable audit trail; (4) preserve operability in low-bandwidth or rural environments through local caching and queued synchronization on reconnection; and (5) sustain a 99.9% uptime target through cloud-hosted, horizontally scalable infrastructure.

2.1 Key Product Features and Capabilities

PatientPath delivers integrated capabilities that together replace the fax workflow and address the six problem characteristics identified in Section 1. The user-facing features include secure record upload, real-time record sharing across organizations, automated referral tracking, patient consent management, transfer status visibility, multi-factor authentication, and offline sync resilience. The infrastructure features include FHIR/HL7 integration, an EHR adapter layer, end-to-end encryption, role-based access control, audit logging, and a high-availability cloud architecture.

Secure record upload validates files for format and completeness, encrypts them with AES-256 through a cloud key management service, and writes them to encrypted document storage against a five-second target completion time. The five-second figure is a usability target rather than a regulatory one, set so that the upload finishes inside the patient encounter rather than becoming a task the provider defers to the end of the day, which is the behavior that makes records go missing in the current workflow.

Real-time record sharing follows immediately: on referral creation the platform issues a scoped, time-limited IAM access token to the receiving organization, and both the provider and specialist dashboards update instantly with no manual handoff. Automated referral tracking begins from a single-form initiation and advances the referral through automatic status transitions from Pending to In Review to Accepted to Complete; referrals that remain inactive for 48 hours generate an administrative alert, and unresolved cases escalate to a supervisor at 72 hours. These intervals are derived from the referral-loop failure documented in Section 1 (Patel et al., 2018) rather than chosen for convenience: they are set to force human intervention within

two business days, before an unacknowledged referral becomes operationally indistinguishable from a fax that was never received. Patient consent management allows patients to grant and revoke record access from the patient portal, and revocations propagate to all active IAM sessions in real time, immediately invalidating the associated access tokens.

The remaining capabilities govern security and resilience. Multi-factor authentication requires TOTP two-step verification at every login. NIST digital identity guidance obligates a verifier to throttle consecutive failed authentication attempts but sets only an upper bound on how permissive that throttling may be (Temoshok et al., 2025). PatientPath places its logout threshold at three attempts, far inside that bound, on the judgment that clinical users authenticating from known devices have little legitimate need for a wider margin. The accompanying administrative alert carries a 30-second target. Offline sync capability caches recently accessed records locally during outages and reconciles queued writes with the server within 60 seconds of reconnection, treating server state as the source of truth in conflict resolution. FHIR and HL7 integration supplies a configurable translation layer that maps EHR data to FHIR R4 and supports HL7 v2.x message queuing, allowing records originating in different vendor systems to share a single normalized representation. Finally, end-to-end encryption with role-based access control combines AES-256 at rest and TLS 1.3 in transit, four enforced roles evaluated on every API request, and a 90-day key cryptoperiod enforced through cloud KMS. The regulatory posture here is worth stating precisely. The HIPAA Security Rule classifies encryption of electronic protected health information as an addressable rather than a required specification (45 C.F.R. § 164.312), meaning a covered entity may decline it provided it documents why the control is not reasonable and appropriate. PatientPath treats encryption as required regardless, on the position that no such documentation is defensible for records crossing

organizational boundaries over the public internet. The 90-day rotation interval follows the cryptoperiod guidance in NIST SP 800-57 (Barker, 2020), which bounds the operational lifetime of a symmetric key rather than leaving it open-ended.

What makes PatientPath significant is the combination of three properties that competing solutions do not offer together. First, the platform is EHR-agnostic and bridges existing systems rather than replacing them, meaning organizations adopt PatientPath without a multi-million-dollar EHR migration. Second, offline sync resilience makes the platform usable in rural and low-bandwidth clinics, which traditional digital fax replacements and cloud-only HIE solutions cannot serve. Third, the single-form referral workflow with immediate consent-to-access tokenization collapses what is currently a multi-step manual process into a single transaction, directly eliminating the bottlenecks responsible for the failure of fax-based transfers in the first place.

The quantitative values stated above are not of uniform origin, and the distinction governs how each should be treated during implementation and testing. Three are externally anchored. Encryption of electronic protected health information is a Security Rule safeguard (45 C.F.R. § 164.312), which PatientPath treats as mandatory and implements with AES-256 and TLS 1.3; the 90-day key cryptoperiod is set within the maximum that NIST key management guidance permits (Barker, 2020); and the obligation to throttle failed authentication attempts follows from NIST digital identity guidance (Temoshok et al., 2025). Two are evidence-derived and traceable to the problem characteristics established in Section 1: the 48-hour and 72-hour thresholds exist because referral loops measurably fail to close without a forcing function (Patel et al., 2018), and offline sync exists because the target clinics operate on the constrained connectivity the national interoperability data documents (ASTP/ONC, 2024). The remainder are internally set

performance targets — the five-second upload, the 30-second lockout alert, the 60-second post-reconnection reconciliation, the three-attempt lockout threshold, and the 99.9% uptime objective. These reflect the team’s judgment of acceptable system behavior rather than any mandate originating outside the project, and each will be validated against measured performance during prototype testing. Where measured behavior diverges from the target, it is the target that changes.

2.2 Major Components (Hardware/Software)

PatientPath does not require dedicated hardware on the customer side. The platform is hosted on commodity cloud infrastructure (AWS, Azure, or GCP, selected per deployment), and end users access the system through standard web browsers on any current desktop, tablet, or mobile device. Production deployment requires a load-balanced application tier behind a cloud-managed API gateway, an active-passive PostgreSQL cluster with replication across availability zones for high availability, encrypted object storage for document blobs, and a managed key management service (AWS KMS or Azure Key Vault) for AES-256 key custody and rotation. Cached reads and queued writes for offline mode are held client-side in the browser through Service Worker storage and IndexedDB, requiring no installed software.

The software is structured according to the three-layer Major Functional Component Diagram (MFCD) defined in the team’s design deck. The Presentation Layer contains the four user-facing interfaces — Provider Dashboard, Patient Portal, Admin Console, and Login/MFA screens — along with the notification interface, all rendered as a React single-page application. The Application Layer sits behind a single API gateway and contains the platform’s business logic, organized into four services: the Secure Record Exchange Service, Identity and Access Management, Patient Record Management, and the FHIR/HL7 Integration Service. The Data

Layer holds the encrypted document storage for medical records, a PostgreSQL database for users and organizations, a separate FHIR-normalized data store, an append-only audit log database, and the consent records store.

The software stack consists of TypeScript with React on the front end and TypeScript with Node.js and Express on the back end. PostgreSQL serves as the primary relational database, accessed through Prisma as the ORM. WebSockets push real-time status updates to dashboards. Authentication is built on Speakeasy for TOTP-based MFA and OAuth 2.0 / OpenID Connect for hospital SSO integration. Encryption uses TLS 1.3 in transit and AES-256 at rest, with keys held in AWS KMS or Azure Key Vault. CI/CD runs through GitHub Actions, with Jest as the testing framework, and source control is managed in GitHub. The interoperability layer is built against the HL7 FHIR R4 specification with HL7 v2.x message support for legacy EHR queues.

3 Eight participants spanning the four primary user roles and system administrator

Identification of Case Study

PatientPath is being developed for the small-to-mid-size primary care practices, specialty clinics, and federally qualified health centers (FQHCs) that carry the highest cost from fragmented record exchange and show the lowest levels of meaningful interoperability (ASTP/ONC, 2024; ONC, 2022). The case study group is drawn from a single organization in that segment: Southside Community Health Network, a rural Virginia provider network operating a primary care clinic in Emporia and holding standing referral relationships with specialty practices in Richmond and Norfolk. The group consists of eight participants spanning the four primary user roles, plus one system administrator. Two primary care providers initiate referrals and upload supporting records. Two specialists receive those referrals and return consult results. One administrative coordinator monitors referral status and validates incoming records. One system administrator provisions accounts and reviews the audit log. Two patients exercise consent and transfer visibility from the patient portal. Drawing the entire group from a single network allows the team to observe a complete referral loop end to end, from the patient encounter through consent, transmission, receipt, and acknowledgment, within one organizational boundary it can directly instrument.

The case study exercises the user-facing workflows described in Section 2.1, arranged so that each participant encounters the capabilities that matter to their role. The providers exercise multi-factor authentication at login, secure record upload with AES-256 encryption, and single-

form referral creation, which together replace the assemble-and-fax sequence that currently consumes staff time before a referral leaves the building. The specialists exercise real-time record sharing and FHIR-normalized retrieval, receiving a complete record set at the moment of referral rather than an incomplete fax that has to be chased, which is the condition most directly responsible for repeat diagnostics. The administrative coordinator exercises automated referral tracking, including the 48-hour stale-referral alert and the 72-hour supervisor escalation, replacing the manual follow-up log that is currently the only mechanism keeping referral loops from going silent. The patients exercise consent grant and revocation along with transfer status visibility, gaining a view of where their records are and who holds access to them that the fax workflow cannot provide at all. The system administrator exercises role-based access control and the immutable audit log. Offline sync is exercised across all provider-side roles, since intermittent connectivity is a normal operating condition for this network rather than an exceptional one.

A representative scenario begins on a Monday morning at the Emporia clinic, where a primary care provider sees a 58-year-old patient presenting with new-onset chest tightness and determines that a cardiology consult is warranted. The provider authenticates with TOTP verification, and the patient grants record-sharing consent from the patient portal on a clinic tablet before leaving the exam room. The provider uploads the ECG tracing and the most recent lipid and metabolic panels, which are validated, encrypted with AES-256, and written to encrypted storage in under five seconds. A single referral form addressed to the Richmond cardiology practice issues a scoped, time-limited access token to that organization, and the cardiologist's dashboard reflects the new referral immediately, with the uploaded records normalized to FHIR R4 despite having originated in a different vendor's EHR. Later that

afternoon a storm takes the clinic's connection down; the provider continues reading cached patient records, and the two notes written during the outage reconcile with the server within 60 seconds of reconnection. The referral sits at Pending overnight, and at the 48-hour mark the administrative coordinator receives a stale-referral alert, follows up, and the cardiology practice moves the referral to In Review the same day. The patient, checking the portal from home, can see that the records were received and that the consult has been scheduled. When the cardiologist returns the consult note four days later, the referral advances to Complete and the loop closes without a single fax, resend, or phone call to confirm receipt. Reviewing the audit log afterward, the system administrator can reconstruct every access to that patient's record, by whom and when, from encounter to closure.

A full-capability implementation expands this scenario along the dimensions the case study deliberately holds fixed. Live EHR adapters would replace manual upload, authenticating directly against Epic, Oracle Health, and eClinicalWorks so that records flow out of production systems without a provider assembling them by hand. Hospital single sign-on through OAuth 2.0 and OpenID Connect would replace the local credential store, letting providers reach PatientPath with the identity their organization already issues them. Production key management, SMS and email notification gateways, and multi-region deployment against a 99.9% uptime target would move the platform from a demonstrable workflow to one a clinic could depend on during business hours. Self-service organization onboarding would remove the development team from the provisioning path entirely, and formal HIPAA audit, SOC 2 Type II certification, and annual penetration testing would be completed before any handling of live protected health information.

Once validated against this initial group, PatientPath is positioned for expansion to a broader user base that shares the same structural pain points. Future users include behavioral health

providers (with whom only 17% of hospitals routinely exchange records; ASTP/ONC, 2024).

long-term and post-acute care facilities, multi-specialty group practices, regional Health Information Exchanges (HIEs) seeking a low-friction onboarding option for smaller member organizations, and larger hospital systems that need to coordinate referrals with the rural and specialty practices in their catchment area. The plugin-based EHR integration model is intended to support this expansion without requiring core platform changes for each new participating organization.

4 Glossary

AES-256 (Advanced Encryption Standard, 256-bit key): A symmetric encryption algorithm standardized by the National Institute of Standards and Technology (NIST). PatientPath uses AES-256 to encrypt stored medical records and database contents.

API (Application Programming Interface): A defined set of rules that allows software systems to request data and services from one another. PatientPath exposes all of its services through a single API gateway.

Audit log: A chronological, append-only record of every access to and action taken on patient data, used to reconstruct who viewed or changed a record and when.

CI/CD (Continuous Integration/Continuous Deployment): A development practice in which code changes are automatically built, tested, and released through a pipeline. PatientPath uses GitHub Actions for CI/CD.

Cryptoperiod: The length of time a cryptographic key is authorized for use before it must be replaced. PatientPath sets a 90-day cryptoperiod for its encryption keys.

EHR (Electronic Health Record): A digital record of a patient's medical history maintained by a healthcare organization in a vendor system such as Epic, Oracle Health, or eClinicalWorks.

EHR adapter layer: The PatientPath integration component that connects to an organization's existing EHR and translates its data into FHIR R4, allowing the organization to participate without replacing its EHR.

ePHI (Electronic Protected Health Information): Individually identifiable health information that is created, stored, or transmitted electronically and that the HIPAA Security Rule requires covered entities to safeguard.

FHIR R4 (Fast Healthcare Interoperability Resources, Release 4): The HL7 standard for representing and exchanging health data through web-based APIs. PatientPath normalizes all incoming records to FHIR R4.

FQHC (Federally Qualified Health Center): A community-based health center that receives federal funding to provide primary care services in medically underserved areas.

HIE (Health Information Exchange): An organization or network that enables the electronic sharing of patient health information among providers within a region.

HIPAA (Health Insurance Portability and Accountability Act): The 1996 U.S. federal law whose Privacy and Security Rules establish national standards for protecting patient health information.

HL7 (Health Level Seven International): The standards organization that publishes FHIR and the HL7 v2.x messaging standard still used by many legacy EHR systems.

IAM (Identity and Access Management): The PatientPath service that authenticates users, enforces role permissions, and issues and revokes access tokens.

Interoperability: The ability of separate information systems to exchange data and use the information exchanged. The Office of the National Coordinator for Health Information Technology measures hospital interoperability across four domains: sending, receiving, finding, and integrating records.

KMS (Key Management Service): A cloud service, such as AWS KMS or Azure Key Vault, that generates, stores, and rotates encryption keys on behalf of an application.

MFA (Multi-Factor Authentication): An authentication method that requires two or more independent forms of verification. PatientPath requires a password and a TOTP code at every login.

MFCD (Major Functional Component Diagram): The team’s architectural diagram that divides PatientPath into presentation, application, and data layers.

OAuth 2.0/OIDC (OpenID Connect): Open standards for delegated authorization and identity verification that allow users to sign in to PatientPath with credentials issued by their own organization.

Offline sync: The PatientPath capability that caches recently accessed records in the browser during a connectivity outage and reconciles queued changes with the server once connectivity returns.

ORM (Object-Relational Mapping): A software layer that maps database tables to programming-language objects. PatientPath uses Prisma as its ORM.

PCP (Primary Care Provider): The physician or clinician who delivers a patient’s routine care and initiates referrals to specialists.

RBAC (Role-Based Access Control): An access control model that grants permissions according to a user’s assigned role rather than individual identity. PatientPath evaluates role permissions on every API request.

Referral loop: The complete cycle of a specialist referral, from the referring provider’s request through the specialist’s receipt, consultation, and return of results. The loop is closed when the results reach the referring provider.

Scoped access token: A time-limited credential issued to a receiving organization that grants access only to the records attached to a specific referral and is invalidated when the patient revokes consent.

SSO (Single Sign-On): An authentication arrangement that allows a user to access multiple systems with one set of organizational credentials.

Stale referral: A PatientPath referral with no status change for 48 hours. A stale referral triggers an administrative alert and, if still unresolved at 72 hours, escalation to a supervisor.

TLS 1.3 (Transport Layer Security, Version 1.3): The current version of the cryptographic protocol that protects data in transit between clients and servers.

TOTP (Time-Based One-Time Password): A short numeric code generated by an authenticator app that changes at a fixed interval, typically every 30 seconds. PatientPath uses TOTP as the second factor in multi-factor authentication.

5 References

Assistant Secretary for Technology Policy/Office of the National Coordinator for Health

Information Technology. (2024). *Interoperable exchange of patient health information among U.S. hospitals: 2023* (Data Brief No. 71). <https://healthit.gov/data/data-briefs/interoperable-exchange-patient-health-information-among-us-hospitals-2023/>

Barker, E. (2020). *Recommendation for key management: Part 1 — General* (NIST Special Publication 800-57 Part 1, Rev. 5). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-57pt1r5>

De Swart, M. E., Zonderhuis, B. M., Hellingman, T., Kuiper, B. I., Dickhoff, C., Heineman, D. J., Hendrickx, J. J., Kouwenhoven, M. C. M., Van Moorselaar, R. J. A., Schuur, M., Tenhagen, M., Van Der Velde, S., De Witt Hamer, P. C., Zijlstra, J. M., & Kazemier, G. (2023). Incomplete patient information exchange and unnecessary repeat diagnostics during oncological referrals in the Netherlands: Exploring the role of information exchange. *Health Informatics Journal*, 29(1), 14604582231153795. <https://doi.org/10.1177/14604582231153795>

Office of the National Coordinator for Health Information Technology. (2020, February). *Strategy on reducing regulatory and administrative burden relating to the use of health IT and EHRs*. <https://healthit.gov/wp-content/uploads/2020/02/BurdenReport.pdf>

Office of the National Coordinator for Health Information Technology. (2022, July). *Interoperability among office-based physicians in 2019* (Data Brief No. 59). <https://healthit.gov/data/data-briefs/interoperability-among-office-based-physicians-2019/>

Office of the National Coordinator for Health Information Technology. (2023, January). *Interoperability and methods of exchange among hospitals in 2021* (Data Brief No. 64).

<https://healthit.gov/data/data-briefs/interoperability-and-methods-exchange-among-hospitals-2021/>

Patel, M. P., Schettini, P., O’Leary, C. P., Bosworth, H. B., Anderson, J. B., & Shah, K. P.

(2018). Closing the referral loop: An analysis of primary care referrals to specialists in a large health system. *Journal of General Internal Medicine*, 33(5), 715–721.

<https://doi.org/10.1007/s11606-018-4392-z>

Security Standards for the Protection of Electronic Protected Health Information, 45 C.F.R. § 164.312 (2013).

Temoshok, D., Choong, Y.-Y., Regenscheid, A., Galluzzo, R., Fenton, J., Richer, J., &

Lefkovitz, N. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST Special Publication 800-63B-4). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-63B-4>